

# Comprehensive Penetration Testing & VAPT Report

## Enterprise Security Capstone — Executive Committee Edition

**Prepared by:** Darshan Suresh

**Assessment period:** [INSERT LAB DATES]

**Environment:** Authorized simulated/training environment

### CONFIDENTIAL — TRAINING ASSESSMENT

This report consolidates network, web-application, and cryptographic/security-authentication assessments into an executive-ready VAPT deliverable. Target-specific findings, evidence, and CVSS vectors must be completed from the actual lab results before final mentor submission.

# 1. Executive Summary

The assessment was designed to evaluate the security posture of an authorized simulated environment across three complementary domains: network exposure, web-application security, and cryptographic/authentication controls. Testing follows a defense-oriented methodology intended to identify weaknesses, demonstrate controlled impact, and provide prioritized remediation guidance.

The engagement is structured around evidence-driven findings. The final report should distinguish confirmed vulnerabilities from observations and recommendations. No claim in this template should be treated as a confirmed vulnerability until supported by the corresponding lab output or screenshot.

## Objectives

- Identify externally visible network services and potential exposure.
- Assess common OWASP web-application weaknesses in an intentionally vulnerable application.
- Review implementation of modern cryptographic primitives and password hashing.
- Translate technical observations into business risk, CVSS 3.1 metrics, and remediation timelines.
- Provide developers and system administrators with actionable patch guidance.

## 2. Scope, Rules of Engagement & Methodology

**Scope:** [INSERT TARGET/HOSTNAMES], [INSERT WEB APPLICATION], and the cryptographic demonstration code. Testing must remain inside the authorized sandbox.

**Out of scope:** third-party systems, production services, denial-of-service testing, destructive exploitation, persistence, and unauthorized data access.

### Methodology

Reconnaissance → service discovery → vulnerability identification → controlled proof of concept → evidence capture → risk analysis → remediation → retest.

### Evidence Standard

Every confirmed finding should include the affected component, reproduction conditions, screenshot or command output, impact, root cause, remediation, and retest criteria.

### 3. Risk Management & CVSS 3.1

CVSS 3.1 provides a standardized severity framework, but a final score depends on the actual attack vector, privileges, user interaction, scope, confidentiality, integrity, and availability impacts of each specific finding.

| Severity      | CVSS v3.1 range | Suggested remediation target |
|---------------|-----------------|------------------------------|
| Critical      | 9.0–10.0        | Immediate / emergency        |
| High          | 7.0–8.9         | ≤ 7 days                     |
| Medium        | 4.0–6.9         | ≤ 30 days                    |
| Low           | 0.1–3.9         | ≤ 90 days                    |
| Informational | N/A             | Track / improve control      |

These remediation targets are project-management guidance, not a substitute for organizational risk acceptance or formal vulnerability-management SLAs.

## 4. Network Security Assessment

Network reconnaissance uses Nmap to identify reachable TCP/UDP services, versions, and operating-system indicators. Wireshark is used to inspect authorized lab traffic for plaintext protocols, unexpected services, or anomalous communication.

### Planned Tests

- TCP SYN scan
- UDP top-port scan
- Service/version detection
- OS detection
- Packet capture and protocol analysis

### Network Findings Table

| ID   | Asset    | Port/Service | Observation | CVSS     | Status           |
|------|----------|--------------|-------------|----------|------------------|
| N-01 | [INSERT] | [INSERT]     | [INSERT]    | [INSERT] | [Confirmed/Obs.] |
| N-02 | [INSERT] | [INSERT]     | [INSERT]    | [INSERT] | [Confirmed/Obs.] |

## 5. Network Technical Findings

### N-01 — Exposed Service / Configuration

**Asset:** [INSERT] **Port:** [INSERT] **Service:** [INSERT]

**Evidence:** [INSERT NMAP FILE/SCREENSHOT]

**Technical analysis:** Explain why the service is exposed, whether it is necessary, observed version/configuration, and what security consequence is supported by evidence.

**Remediation:** Disable unnecessary services; restrict required services with firewall/ACL controls; patch supported software; enforce secure configuration.

### N-02 — Wireshark Observation

**Protocol:** [INSERT] **Evidence:** [INSERT SCREENSHOT]

Document whether authentication or sensitive data is transmitted without adequate protection. Do not publish real credentials.

## 6. Web Application Security Assessment

The web assessment targets an intentionally vulnerable Juice Shop/DVWA-style application. Testing focuses on SQL Injection, Reflected XSS, Stored XSS, and BOLA/IDOR.

| ID   | Vulnerability | OWASP area                | Evidence | CVSS     | Status   |
|------|---------------|---------------------------|----------|----------|----------|
| W-01 | SQL Injection | A03 Injection             | [INSERT] | [INSERT] | [INSERT] |
| W-02 | Reflected XSS | A03 Injection             | [INSERT] | [INSERT] | [INSERT] |
| W-03 | Stored XSS    | A03 Injection             | [INSERT] | [INSERT] | [INSERT] |
| W-04 | BOLA/IDOR     | A01 Broken Access Control | [INSERT] | [INSERT] | [INSERT] |

## 7. SQL Injection — Technical Finding

**Finding ID:** W-01

**Endpoint/parameter:** [INSERT]

**Reproduction:** Describe the non-destructive lab test and observed behavior. Do not include credentials or destructive payloads.

**Evidence:** [INSERT SCREENSHOT]

**Impact:** Depending on the affected query and database permissions, SQL injection can permit unauthorized query manipulation and potentially affect confidentiality, integrity, or availability.

**Root cause:** Usually caused by constructing SQL with untrusted input instead of parameterized queries.

**Remediation:** Use parameterized queries/prepared statements, least-privilege DB accounts, safe error handling, and security regression tests.

## 8. Cross-Site Scripting — Technical Findings

### W-02 — Reflected XSS

Document the input point, response context, safe proof-of-concept alert, evidence screenshot, impact, and output-encoding remediation.

**Evidence:** [INSERT]

### W-03 — Stored XSS

Document where the input is stored, where it is rendered, the safe proof-of-concept, evidence screenshot, and remediation using context-aware output encoding/sanitization.

**Evidence:** [INSERT]

### Defensive Controls

Prefer safe DOM APIs such as `textContent`, framework auto-escaping, context-aware output encoding, maintained HTML sanitization when HTML is genuinely required, and a restrictive Content-Security-Policy.

## 9. BOLA / IDOR — Technical Finding

**Finding ID:** W-04

Use two authorized lab identities where required. Document the object identifier, request/response comparison, authorization decision, and whether the server verifies ownership or permissions.

**Evidence:** [INSERT REQUEST/RESPONSE SCREENSHOTS]

**Impact:** Object-level authorization failures can allow one authenticated user to access another user's resources.

**Remediation:** Enforce server-side authorization for every object access, deny by default, apply consistent checks across API endpoints, and add horizontal/vertical privilege-boundary tests.

# 10. Cryptography & Secure Authentication Assessment

The cryptographic component demonstrates AES-256-GCM authenticated encryption, RSA-2048 key generation with RSA-PSS signatures, and bcrypt password hashing. The assessment emphasizes safe primitive selection and key lifecycle controls.

| Control        | Implementation  | Security objective          | Evidence |
|----------------|-----------------|-----------------------------|----------|
| AES-256-GCM    | [VERIFY SCRIPT] | Confidentiality + integrity | [INSERT] |
| RSA-2048/PSS   | [VERIFY SCRIPT] | Digital signatures          | [INSERT] |
| bcrypt         | [VERIFY SCRIPT] | Password hashing            | [INSERT] |
| Key management | [VERIFY DOCS]   | Storage/rotation            | [INSERT] |

## 11. Key Management & Secret Protection

Production keys and secrets should never be committed to source control. Prefer KMS/HSM-backed key storage or managed secrets platforms where available. Apply least privilege, separate keys by purpose, audit key access, and maintain key versions when encrypted data needs migration.

### Rotation Lifecycle

Generate → Distribute → Activate → Monitor → Rotate → Revoke → Destroy

AES-GCM requires strict nonce uniqueness for a given key. During key rotation, applications should track the key version associated with ciphertext, decrypt legacy records using the correct version, and re-encrypt with the current key.

## 12. Consolidated Risk Register

| Priority | Finding  | Domain   | OWASP/CWE | CVSS     | Owner       | Target    |
|----------|----------|----------|-----------|----------|-------------|-----------|
| P0       | [INSERT] | [INSERT] | [INSERT]  | [INSERT] | Security/IT | Immediate |
| P1       | [INSERT] | [INSERT] | [INSERT]  | [INSERT] | Dev         | 7 days    |
| P1       | [INSERT] | [INSERT] | [INSERT]  | [INSERT] | Dev         | 7 days    |
| P2       | [INSERT] | [INSERT] | [INSERT]  | [INSERT] | Infra       | 30 days   |
| P3       | [INSERT] | [INSERT] | [INSERT]  | [INSERT] | Platform    | 90 days   |

Priority should be assigned using actual exploitability, business impact, exposure, compensating controls, and organizational risk appetite. Do not equate CVSS alone with business priority.

## 13. Developer Remediation Plan

### **Immediate / P0**

Fix confirmed authorization bypasses, injection paths, and exposed secrets. Add regression tests before deployment.

### **Within 7 Days / P1**

Implement server-side authorization, secure input handling, session controls, and security-sensitive API tests.

### **Within 30 Days / P2**

Patch dependencies, improve logging, add security headers, and review cryptographic/key-management controls.

### **Within 90 Days / P3**

Integrate SAST/DAST/dependency scanning into CI/CD, formalize threat modeling, and conduct follow-up testing.

## **14. Sysadmin / Infrastructure Remediation Plan**

### **Immediate**

Disable unnecessary exposed services, restrict administrative ports, patch critical exposed systems, and rotate credentials if compromise is suspected.

### **7 Days**

Review service accounts, firewall rules, authentication events, centralized logging, and TLS configuration.

### **30 Days**

Establish patch compliance reporting, segmentation reviews, backup validation, and vulnerability-management SLAs.

### **90 Days**

Perform authenticated vulnerability scanning, test incident response, and schedule a post-remediation penetration test.

## 15. Retest & Validation Plan

Each confirmed finding should be retested after remediation using the original reproduction conditions. A finding is considered closed only when the vulnerable behavior is no longer reproducible and the relevant security control is demonstrably enforced.

Retest evidence should include the updated request/response, command output, application behavior, and relevant configuration or test results.

### Closure Criteria

- Original vulnerability cannot be reproduced.
- Security control is enforced server-side where applicable.
- Regression test exists for the vulnerability.
- No new equivalent exposure is introduced.
- Evidence is reviewed and accepted by the mentor/security owner.

## 16. Executive Risk Outlook

The capstone demonstrates how technical security testing can be translated into an enterprise risk-management workflow. The executive committee should use the completed risk register to assign accountable owners, deadlines, and risk acceptance decisions.

The final executive conclusion should be based on the verified findings in the completed evidence set. This template deliberately avoids declaring an overall security rating before the actual test results are inserted.

### Recommended Governance Actions

- Track confirmed vulnerabilities to closure with accountable owners.
- Require security regression testing after remediation.
- Maintain centralized secrets and key-management controls.
- Integrate vulnerability scanning into the development and infrastructure lifecycle.
- Schedule periodic independent validation.

## 17. Appendix A — Evidence Index

Network evidence: N-01 through N-05 in evidence/network/.

Web evidence: W-01 through W-04 in evidence/web/.

Cryptography evidence: C-01 through C-04 in evidence/crypto/.

Insert exact filenames, timestamps, and relevant command/output references here before mentor review.

## 18. Appendix B — Reporting Notes

CVSS 3.1 scoring should be completed using the official CVSS calculator or equivalent validated implementation after the vulnerability characteristics are established. OWASP mappings should reflect the applicable category for the assessed application/version.

All screenshots should be sanitized. Remove credentials, tokens, private keys, personal information, internal IPs if required by the submission policy, and unrelated production information.

### Final Quality Gate

- All claims trace to evidence.
- All CVSS vectors are reproducible.
- All findings have remediation owners and timelines.
- The public repository contains no secrets.
- The PDF and repository are consistent.

## 19. Mentor Review Sign-Off

**Mentor:** [INSERT]

**Review date:** [INSERT]

**Comments:** [INSERT]

**Status:** [Approved / Changes Requested]

**Student:** Darshan Suresh

**Repository:** [INSERT PUBLIC GITHUB URL]

**Final report version:** 1.0

End of report.